CRAFT Linux Operating Modes and Tickets

Certificate Request Agent for Tickets | Process overview

CRAFT obtains Kerberos credentials from Linux without storing the user's AD password. Modes 1-3 obtain a user TGT through PKINIT. Mode 4 uses broker constrained delegation to obtain only approved service tickets. Domain membership is not required.

Choose an operating mode

Mode	Credential source and authority	Setup
1 Privileged enrollment	Linux generates a user key and enrolls a certificate through CES and AD CS with an enrollment-agent signature. The CA restricts the agent, template and recipients.	Mode 1 setup
2 Privileged credential linking	Linux adds a temporary public key to the user's msDS-KeyCredentialLink and uses Key Trust PKINIT. AD attribute delegation defines the target scope.	Mode 2 setup
3 Unprivileged Windows export	Windows enrolls and exports a certificate and matching private key. Linux uses the securely transferred PEM pair under the caller's UID.	Mode 3 setup
4 Service tickets only	A dedicated broker uses S4U2Self and S4U2Proxy. AD restricts the target services; the user receives no TGT or broker credentials.	Mode 4 setup

How CRAFT selects the mode

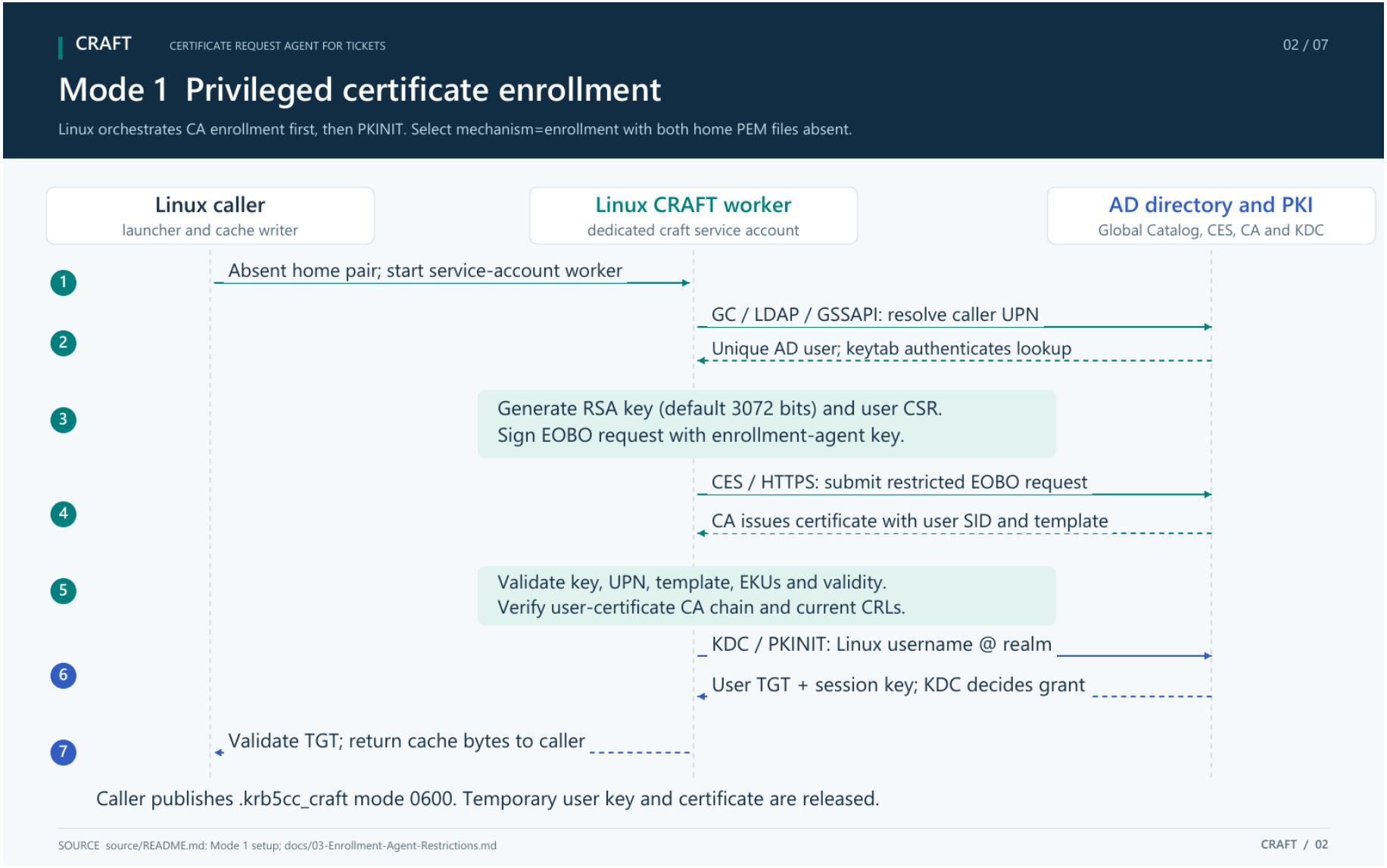
mechanism=constrained_delegation selects mode 4 and ignores home certificates. Otherwise a complete NSS-home ~/.config/craft/user.pem and user.key pair selects mode 3. Partial or invalid pairs fail. Only an absent pair selects enrollment or Key Trust from mechanism; failures never switch mechanisms.

Mode 3 uses ordinary executables. Modes 1, 2 and 4 require the setuid launcher, dedicated craft account, craft-users caller group and private /run/craft. Users run craft directly without sudo. Network work runs outside root; the caller publishes the cache. CRAFT does not perform an MFA challenge.

Mode selection diagram | Build and install

Mode 1 privileged certificate enrollment

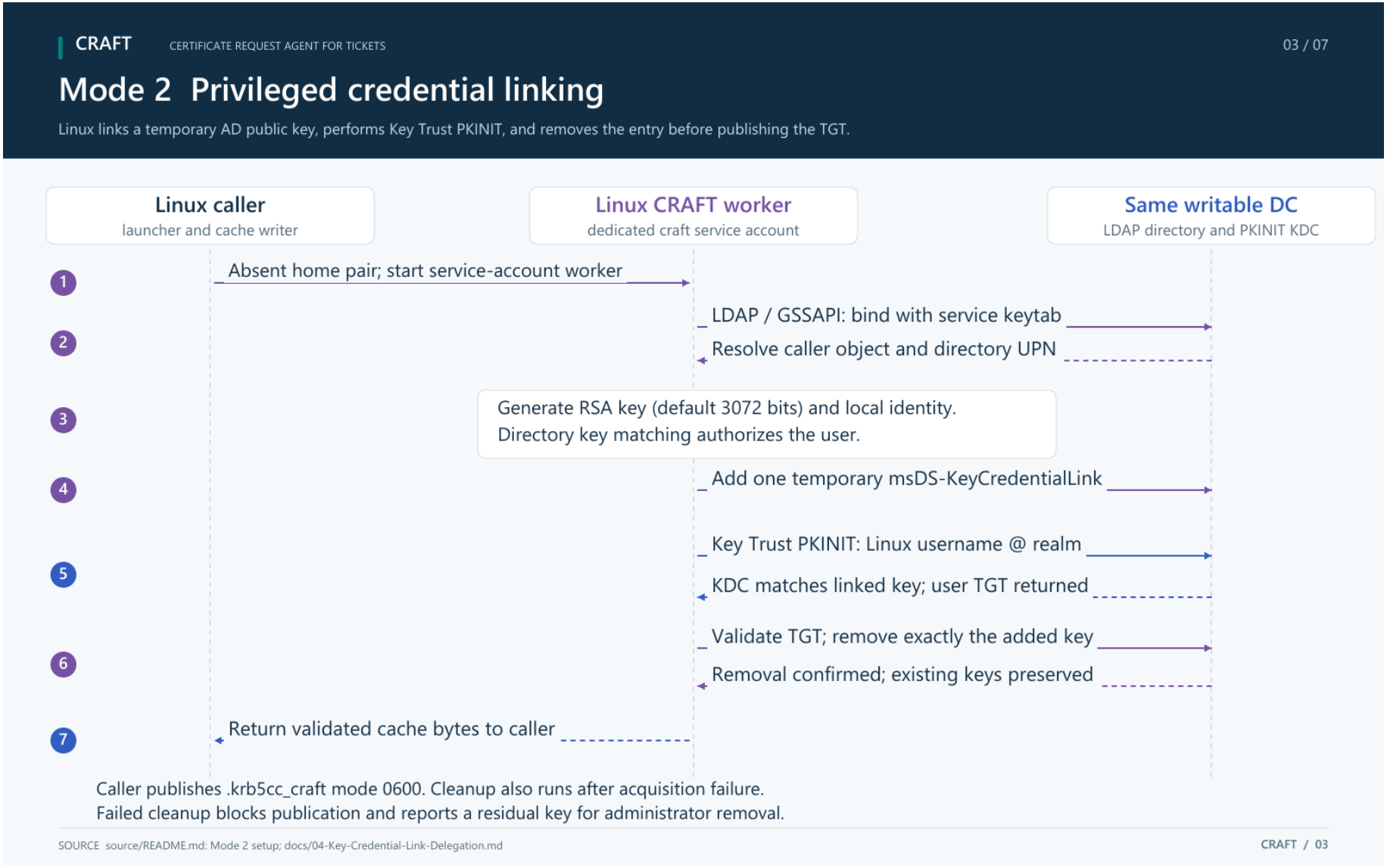
Complete setup instructions | Editable flow diagram



Linux resolves the user, enrolls a restricted certificate through CES and AD CS, then obtains the user's TGT through PKINIT. The generated user pair is temporary; CA records remain.

Mode 2 privileged credential linking

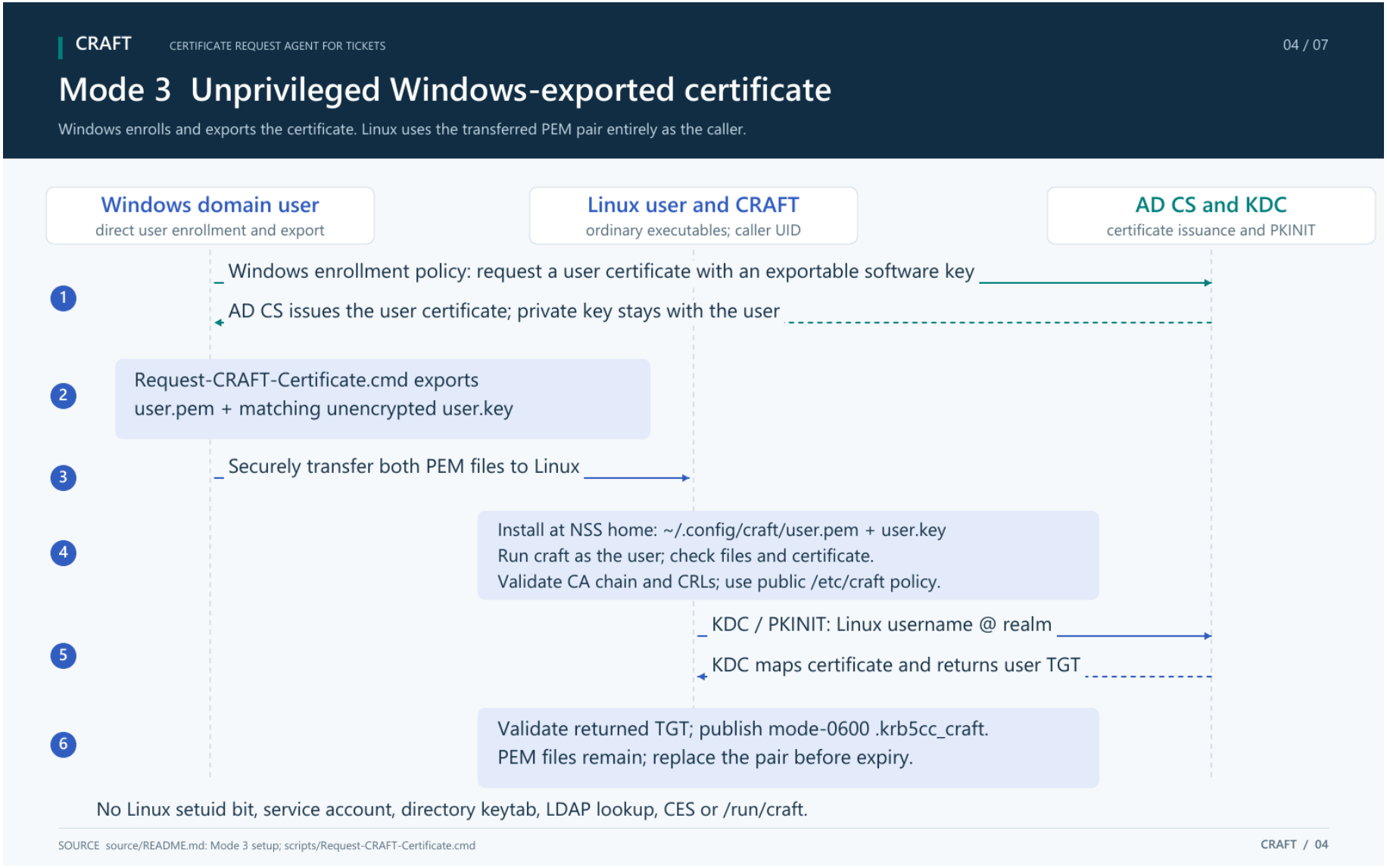
[Complete setup instructions](#) | [Editable flow diagram](#)



Linux uses a delegated directory write and Key Trust PKINIT against the same writable DC. Cleanup must succeed before cache publication. A residual key after an outage needs administrator removal.

Mode 3 unprivileged Windows exported certificate

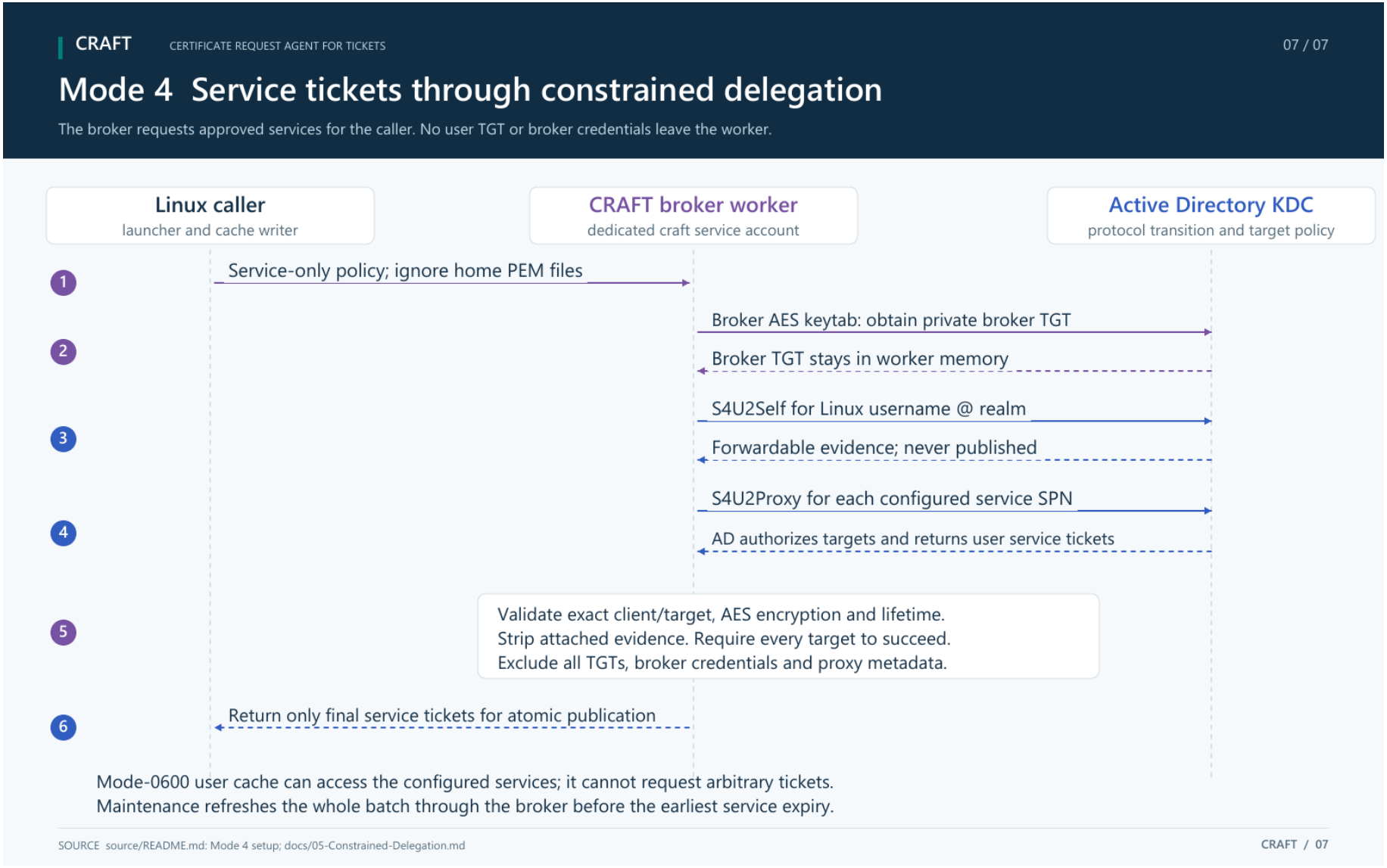
Complete setup instructions | Editable flow diagram



Windows enrollment and export precede secure PEM transfer. Linux validates the supplied pair and obtains the user's TGT as the caller. The PEM pair remains and must be replaced before expiry.

Mode 4 service tickets through constrained delegation

Complete setup instructions | Editable flow diagram



A private broker TGT authorizes protocol transition and constrained delegation. Only validated tickets for every configured service are published. Home PEM files are ignored; there is no PKINIT or directory write.

Identity trust and credential storage

All modes request <Linux username>@<configured realm> and verify the returned credential principals, flags, AES encryption and lifetimes. Linux names must match the intended AD sAMAccountName. Enrollment and credential linking resolve and check the directory UPN. The supplied-certificate path performs no LDAP lookup; the KDC must map that certificate to the fixed caller principal. The certificate CN cannot select another account.

Mode	Client credential and authorization	What persists
1 Enrollment	CA-issued user certificate; matching key, UPN, template, three client EKUs, short validity, CA chain and CRLs. CA recipient restrictions authorize issuance.	Private agent/keytab/transport credentials stay under /etc/craft. CA issuance and audit records remain. Generated user key and certificate are released.
2 Credential linking	Locally issued certificate carrying a fresh RSA public key (default 3072 bits). The KDC matches the linked key; a trusted user-certificate CA chain is unnecessary. KDC trust is still required.	Service keytab and delegated AD rights remain. CRAFT removes its exact directory entry and releases the generated identity. Failed cleanup can leave a standing credential.
3 Supplied certificate	Windows-exported PEM pair; matching key, logon usage, UPN SAN, validity, CA trust and CRLs. KDC account mapping authorizes authentication.	user.pem and user.key stay in the caller's home. CRAFT does not renew, overwrite or delete them. Replace them before expiry.
4 Service tickets	Broker AES keytab, protocol transition and explicit AD target SPNs. No certificate authentication or directory write.	Broker keytab stays protected under /etc/craft. Only final user service tickets and their session keys persist in the user cache.

Every mode atomically publishes a caller-owned mode-0600 .krb5cc_craft in the NSS home. It contains a user TGT in modes 1-3, or only selected service tickets in mode 4, with session keys but no certificate, private key or broker evidence. Modes 1-3 use it to request service tickets. Success replaces the cache; acquisition failure preserves it, and expiration does not delete it automatically.

Generated credentials and sealed PKINIT memory files are released after the operation. Memory can reach swap or privileged host capture. Deleting keys, removing a linked credential, ending a process or removing a cache does not revoke an already-issued ticket. Host and service-account compromise expose the authority granted to that installation.

Enrollment-agent restrictions | Key Trust delegation | Broker delegation

Ticket lifetimes and everyday use

Modes 1-3 request a ten-hour initial TGT and a seven-day renewal window with AES256/AES128. The KDC controls the grant; certificate/key lifetime can constrain initial validity. A renewal window is the period during which an eligible TGT can be renewed. It does not make one ticket valid for seven days.

require_full_tgt_lifetime=yes rejects shortened initial or renewal grants without replacing the cache. Administrators can set no to accept shorter grants with a warning. Returned ticket times are never rewritten. Enrollment certificate caps default to ten hours total, including backdating; they do not cap mode 3's supplied certificate or mode 2's local identity.

Select the user cache

```
cache=$(/usr/local/bin/craft) || exit "$?"
export KRB5CCNAME="$cache"
klist -ef -c "$KRB5CCNAME"
```

Kerberos-aware applications launched from this shell use the selected cache for SMB, LDAP and Kerberos-enabled web services. The service still enforces the user's permissions. CRAFT cannot change its parent shell's environment; the optional with-craft wrapper runs a command with its cache selected.

Maintain a long running job

```
job_pid=$$
cache=$(/usr/local/bin/craft-maintain --watch-pid "$job_pid") || exit "$?"
export KRB5CCNAME="$cache"
```

craft-maintain returns when credentials and detached maintenance are ready. Modes 1-3 renew from the cached TGT and authenticate afresh near the renewal deadline. Mode 4 refreshes the complete service batch through its broker before the earliest expiry. Fresh authentication always uses the configured mode selection.

Install the maintainer without setuid/setgid. Protect system Kerberos configuration, and watch a shell or controller that lasts for the job. The scheduler must retain background processes. Modes 1, 2 and 4 need setuid access for fresh authentication; home refresh works under no_new_privs. --max-duration 21d adds a cutoff. Concurrent jobs for one UID share the cache and acquisition cooldown.

```
/usr/local/bin/craft-maintain --status --watch-pid "$job_pid"
klist -ef -c "$KRB5CCNAME"
```

Failures preserve credentials and retry; later failures do not stop the job. Status and AUTHPRIV logs report failures. Maintenance stops with the watched PID and leaves the cache. Applications must reload refreshed credentials. Keep CRLs current and replace the supplied certificate before expiry; TGT maintenance does not renew it.

Maintenance setup and status | Credential timing diagram

Operation and authorization

Mode 4 uses a dedicated broker with protocol transition and account-based constrained delegation to an exact list of target SPNs. AD limits target services, not the users the broker can impersonate. Protect the keytab, restrict local craft-users membership and control Linux UID/name assignment. Exclude sensitive users through domain delegation policy and test denial against the deployed KDC.

Services sharing an AD account and key are not isolated by their SPN labels. Use separate target service identities where isolation matters. Applications must request the configured service names exactly; aliases or additional services need explicit configuration and AD authorization. A service-only cache cannot acquire arbitrary tickets.

All modes require a working host logging socket at /dev/log. Administrators maintain CRLs, review authorization scope and protect persistent credentials. Setting enabled=no stops fresh acquisition; stop active maintainers separately to end renewal. Issued tickets and service sessions remain subject to domain policy.

Mode 4 refreshes all service tickets through the broker before the earliest expiry. It has no cache-only renewal and needs the broker and KDC for each refresh. Status identifies ticket_kind and ticket_expires. Removing broker delegation blocks fresh acquisition but does not revoke already-issued tickets.

Audit and troubleshooting | Operational disable

References and license

Install and configure | Security and operations | Acceptance checks

PKINIT specification | MIT PKINIT configuration

Source code, scripts, configuration examples and documentation are licensed under GNU GPL version 3 only (GPL-3.0-only). See LICENSE for the terms and warranty disclaimer.